

Unit - 6

1. Firewall Design Principals
2. Trusted Systems
3. Intrusion Detection Systems

Firewalls

- ✓ *Effective means of protecting a local system or n/w of systems from n/w-based security threats*
- ✓ *Also afford access to the outside world via WANs and the Internet*

Overview of Firewalls

Firewall Design Principles	Characteristics
Capabilities	Limitations

Firewall Design Principles

- ✓ *Internet access provides benefits to the user (organization) , it enables the outside world to reach and interact with local network assets. This creates a threat to the organization*
- ✓ *Threats can be defeated by using firewall*

Location: *The firewall is inserted between the premises network and the Internet*

Purpose: *To protect the premises network from Internet-based attacks and to provide a single choke point where security can be imposed*

- ✓ *The firewall may be a single computer system or a set of two or more systems that cooperate to perform the firewall function*

Firewall Characteristics

- 1. All **traffic** from inside to outside, and vice versa, must pass **through the firewall***
- 2. Only **authorized traffic**, as defined by the local security policy, will be allowed to pass. Various types of firewalls are used, which implement various types of security policies*
- 3. The firewall itself is **immune to penetration***
- 4. **Service control**: Determine the types of Internet services that can be accessed*
- 5. **User control**: Controls access to a service according to which user is attempting to access it*

Capabilities of the firewall

1. A firewall defines a single choke point that

- *keeps **unauthorized users** out of the protected network,*
- ***prohibits vulnerable services** from entering or leaving the network, and*
- *provides **protection** from various kinds of **IP spoofing and routing attacks***

2. A firewall provides a location for monitoring security-related events

3. A firewall is convenient platform for several Internet functions that are not security related (e.g., network address translator and network management function)

4. A firewall can serve as the platform for IPSec

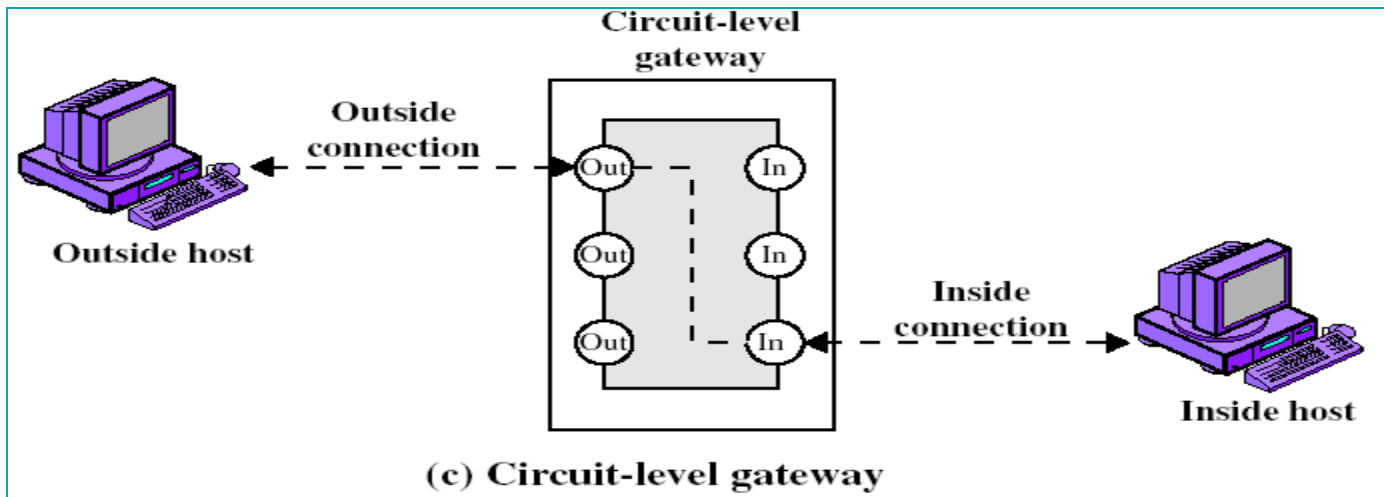
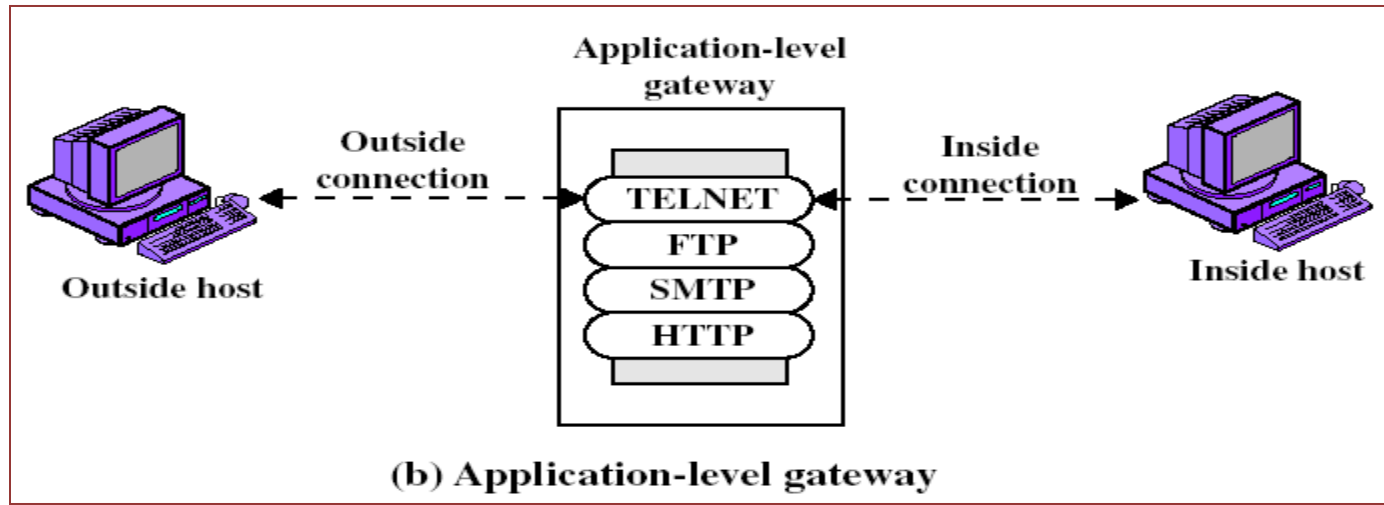
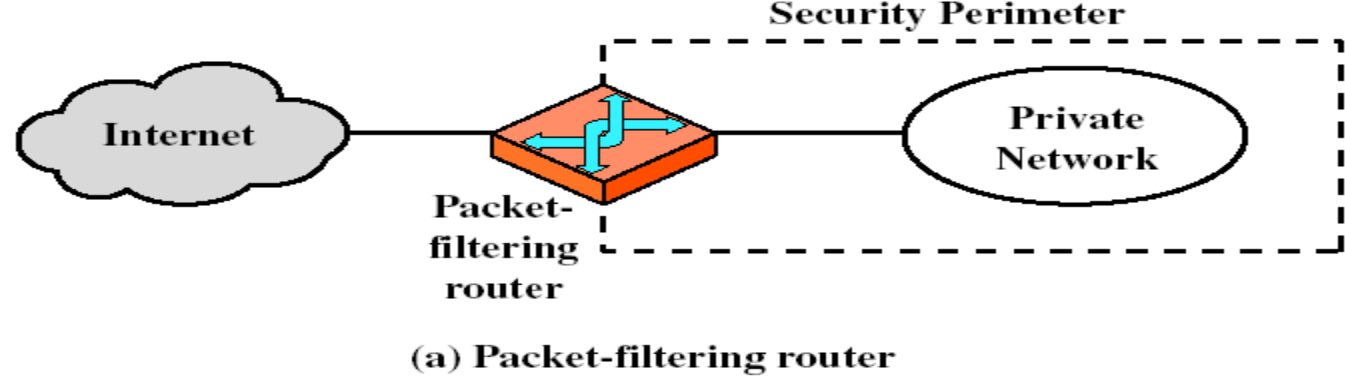
Limitations of the firewall

*1. The firewall cannot protect against attacks that **bypass the firewall**.*

*2. The firewall does not protect against **internal threats***

*3. The firewall cannot protect against the **transfer of virus-infected programs or files***

Types of Firewalls



1.Packet-Filtering Router

What is it? *It applies a set of rules to each incoming IP packet or outgoing IP packet and then forwards or discards the packet*

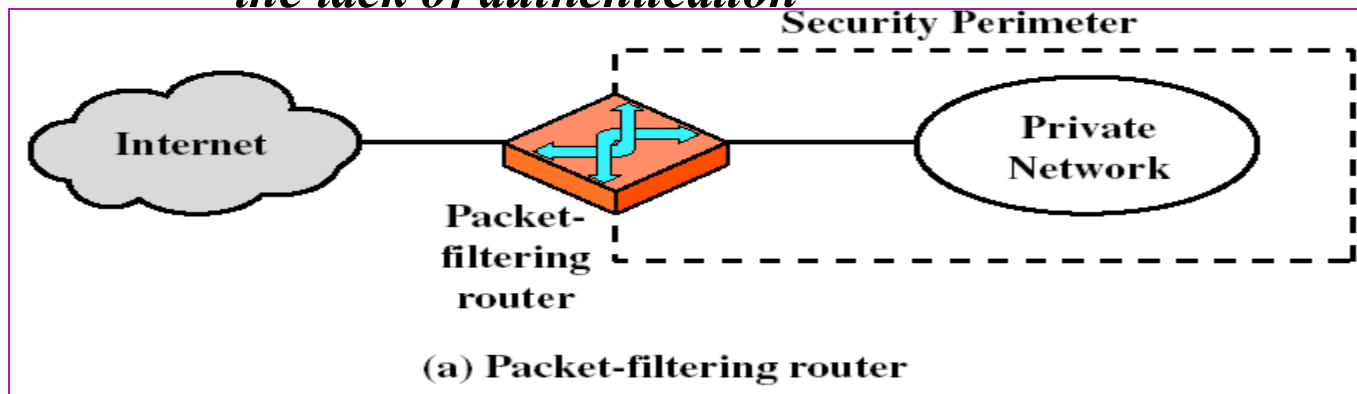
✓ Filtering rules based on fields in

*IP and transport (e.g., TCP or UDP) header, including source and destination IP address,
IP protocol field, and
TCP or UDP port number*

✓ Advantages : *simplicity.*

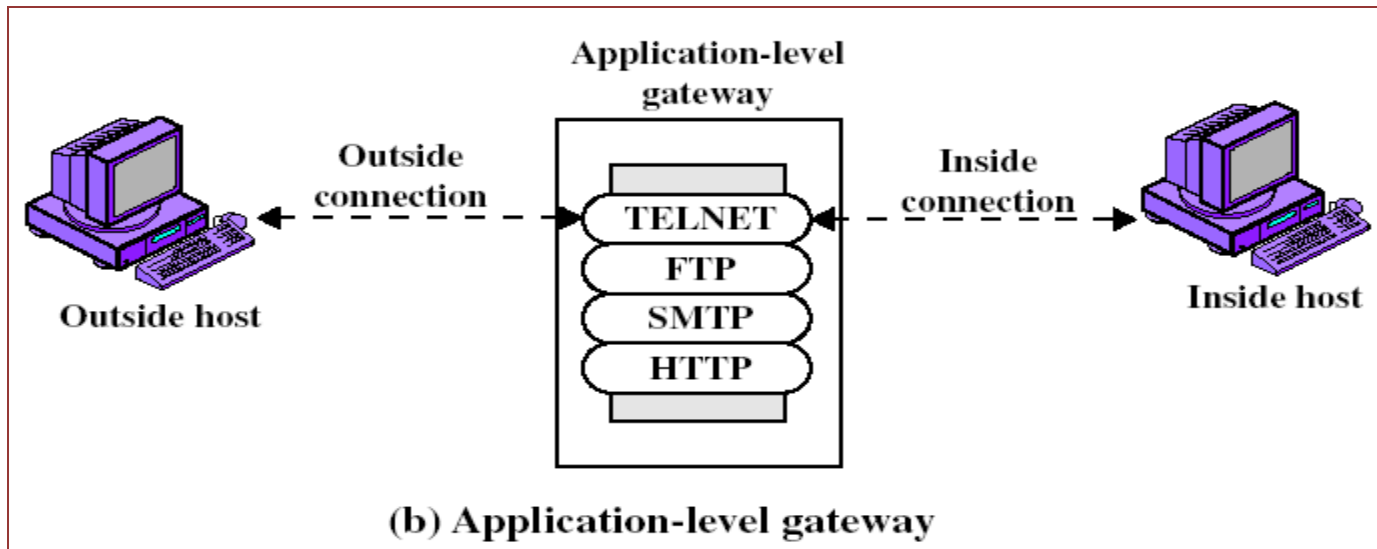
transparent to users and are very fast

✓ Disadvantages :*difficulty of setting up packet filter rules correctly
the lack of authentication*



2.Application-Level Gateway

- ✓ Also called a *proxy server*, acts as a *relay* of application-level traffic
- ✓ The user contacts the gateway using a TCP/IP application, such as Telnet or FTP, and the gateway asks the user for the name of the remote host to be accessed
- ✓ When the user responds and provides a valid user ID and authentication information, the gateway contacts the application on the remote host and relays TCP segments containing the application data between the end points
- ✓ Application-level gateways tend to be more secure than packet filters



3. Circuit-Level Gateway

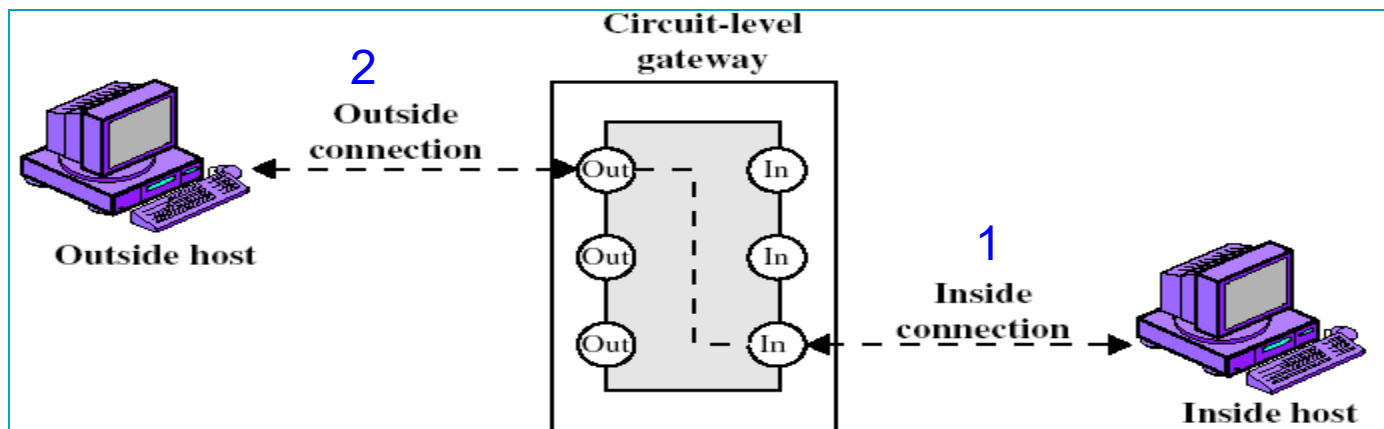
✓ This can be a stand-alone system or it can be a specialized function performed by an application-level gateway for certain functions

✓ It does not permit an end-to-end TCP connection; rather, the gateway sets up two TCP connections,

1. between itself and a TCP user on an inner host and
2. between itself and TCP user on an outside host

✓ Once the two connections are established, the gateway typically relays TCP segments from one connection to the other *without examining the contents*

✓ *Typical Use:* A system where system administrator trusts the internal users

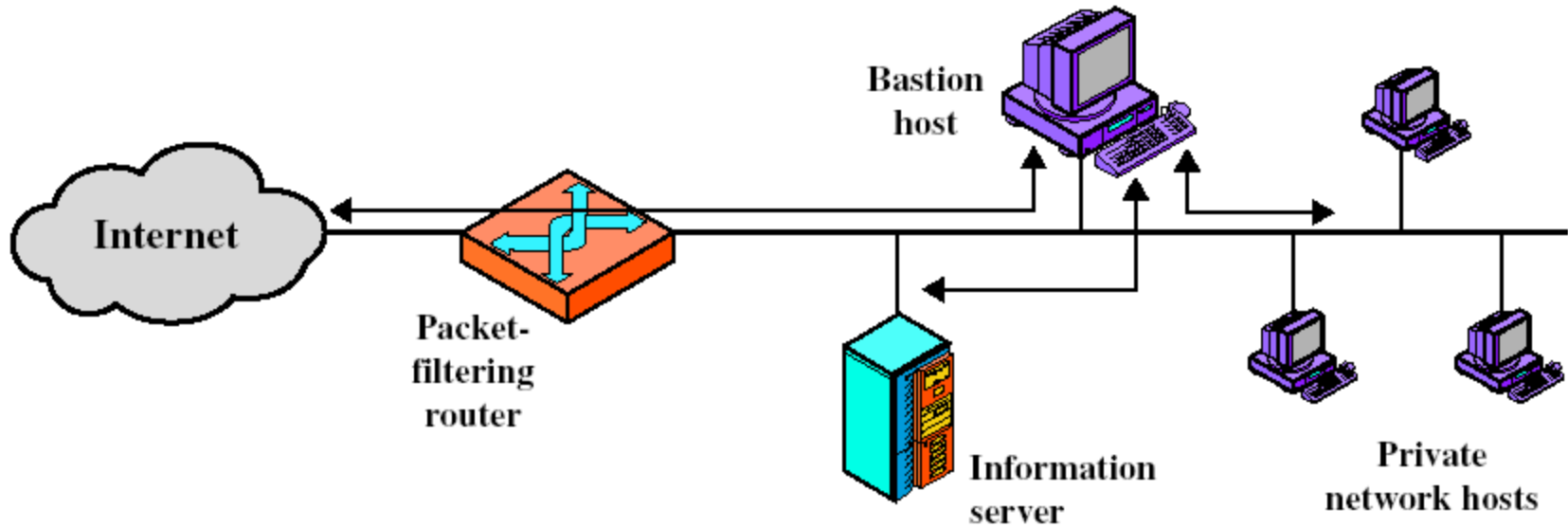


(c) Circuit-level gateway

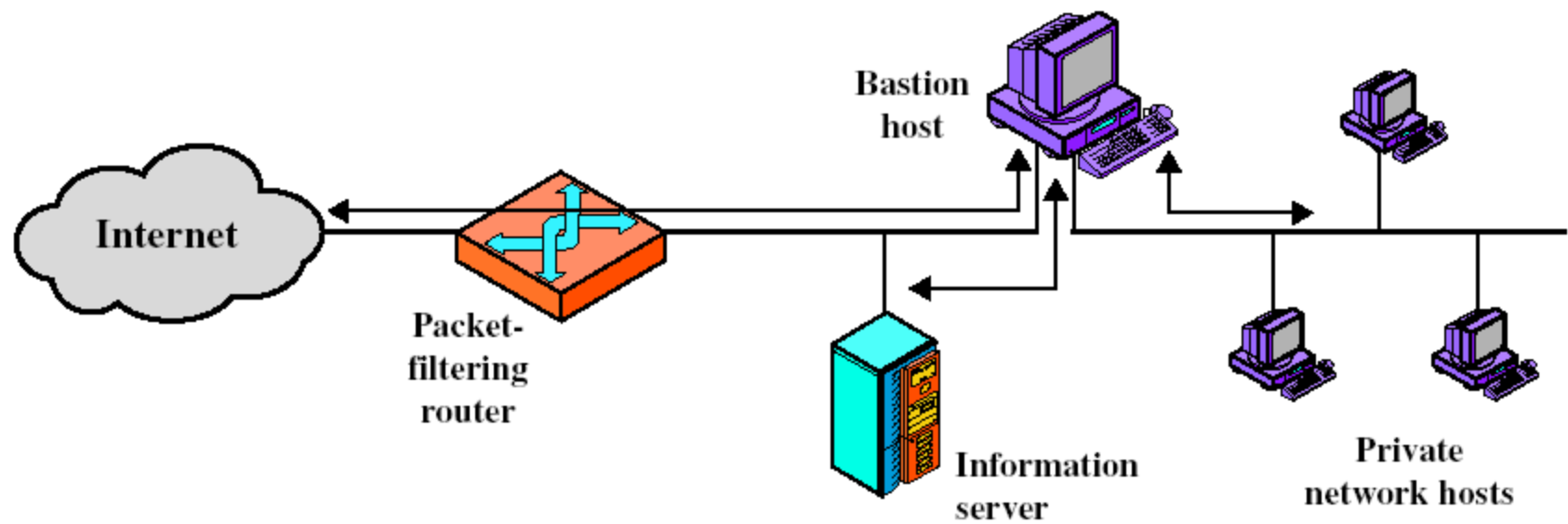
Bastion Host

- ✓ *A bastion host is a system identified by the firewall administrator as a critical strong point in the network's security*
- ✓ *Bastion host serves as a platform for an application-level or circuit-level gateway*

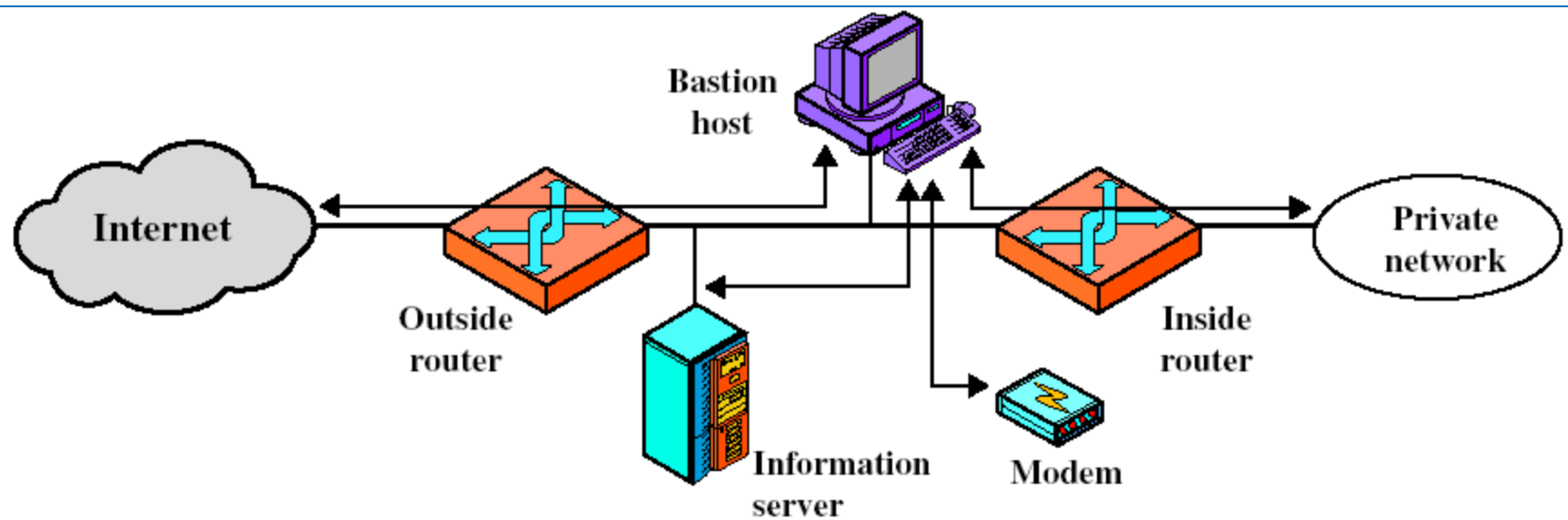
Firewall Configurations



(a) Screened host firewall system (single-homed bastion host)



(b) Screened host firewall system (dual-homed bastion host)



(c) Screened-subnet firewall system

✓ In the screened host firewall, single-homed bastion configuration, the firewall consists of two systems: *a packet-filtering router and a bastion host*

✓ The router is configured so that

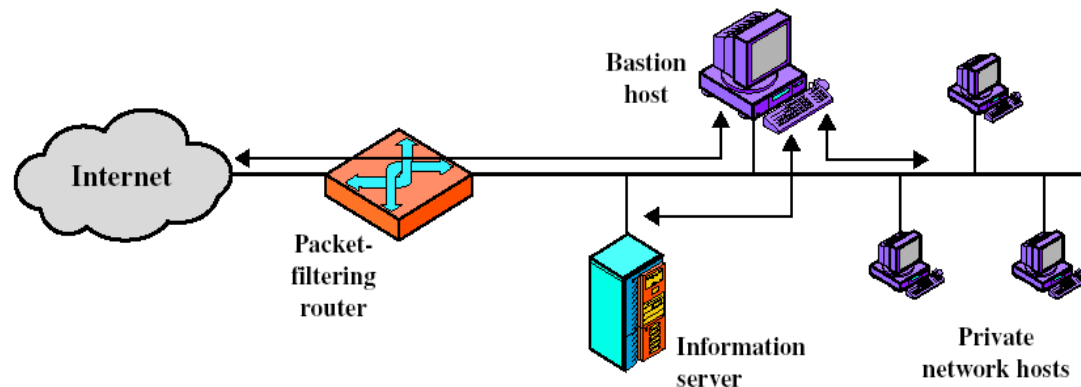
1. For traffic from the Internet, only IP packets destined for the bastion host are allowed in

2. For traffic from the internal network, only IP packets from the bastion host are allowed out

✓ The bastion host *performs authentication and proxy functions*

✓ This configuration has greater security than simply a packet-filtering router or an application-level gateway alone

✓ Here, if the packet-filtering router is completely compromised, traffic could flow directly through the router between the Internet and other hosts on the private network

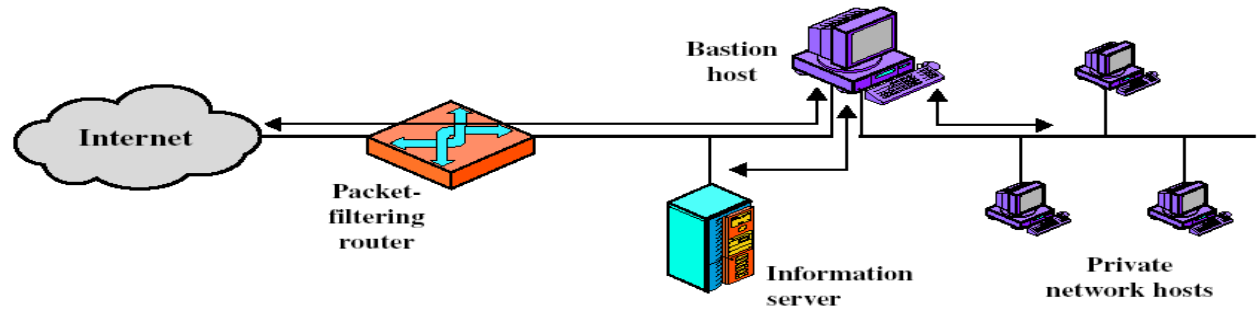


(a) Screened host firewall system (single-homed bastion host)

✓ Screened host firewall, dual-homed bastion configuration *physically prevents such a security breach*

✓ Advantages of dual layers of security of the previous configuration are present here too

✓ Again, an information server or other hosts can be allowed direct communication with the router

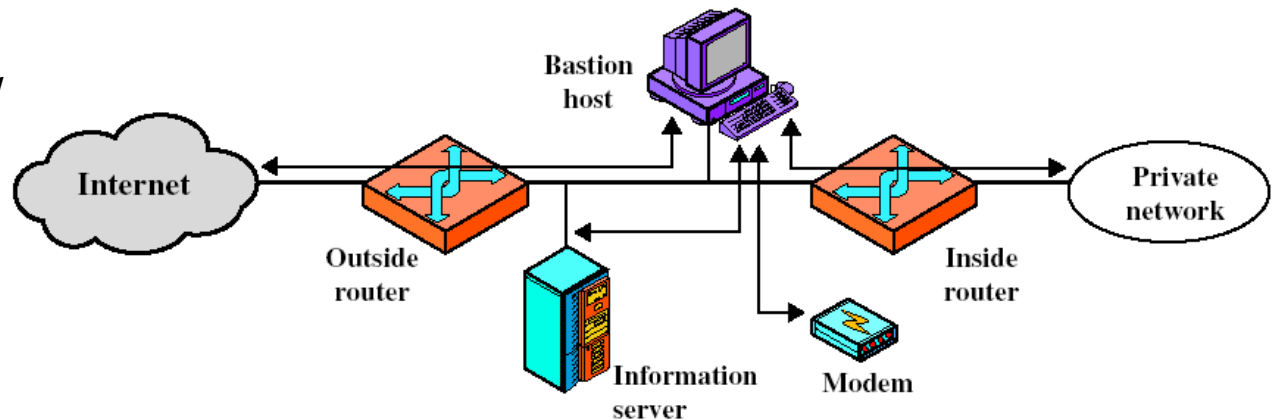


(b) Screened host firewall system (dual-homed bastion host)

✓ The screened subnet firewall configuration is the *most secure*

✓ In this, 2 packet-filtering routers are used, 1-between BH and Internet & 2 - between BH and Internal n/w

✓ This creates an isolated subnetwork, which may consist of simply the BH but may also include 1/more information servers and modems for dial-in capability



(c) Screened-subnet firewall system

✓ Both the Internet and the internal network have access to hosts on the screened subnet, but traffic across the screened subnet is blocked

Trusted Systems

✓ One way to enhance the ability of a system to defend against intruders and malicious programs is to implement trusted system technology

Data Access Control

✓ Following successful logon, the user has been granted access to one or a set of hosts and applications

✓ Through the user access control procedure, a user can be identified to the system

✓ Associated with each user, there can be a profile that specifies permissible operations and file accesses

✓ The operating system can then enforce rules based on the user profile

✓ The database management system, however, must control access to specific records or even portions of records

✓ A general model of access control as exercised by any file or database management system is that of an access matrix (please see next slide)

✓ *The basic elements of the model are as follows:*

- Subject**: *An entity capable of accessing objects. Any user or application actually gains access to an object by means of a process that represents that user or application.*

Object: *Anything to which access is controlled. Examples include files, programs, and segments of memory*

Access
Control
Structures

	Program1	...	SegmentA	SegmentB
Process1	Read Execute		Read Write	
Process2				Read
.				
.				
.				

(a) Access Matrix

Access Control List for Program1: Process1 (Read, Execute)
Access Control List for SegmentA: Process1 (Read, Write)
Access Control List for SegmentB: Process2 (Read)

Capability List for Process1: Program1 (Read, Execute) SegmentA (Read, Write)
Capability List for Process2: SegmentB (Read)

(b) Access Control List

(c) Capability List

-Access right: The way in which an object is accessed by a subject. Examples are read, write, and execute

✓ y-axis of the matrix consists of identified subjects that may attempt data access

✓ x-axis of the matrix consists of objects that may be accessed

✓ Each entry in the matrix indicates the access rights of that subject for that object

✓ In practice, an access matrix is usually sparse and is implemented by decomposition in one of two ways

✓ The matrix may be decomposed by columns, yielding access control lists (Fig b). Thus, for each object, an access control list lists users and their permitted access rights

✓ Decomposition by rows yields capability tickets (Fig c). A capability list specifies authorized objects and operations for a user

The Concept of Trusted Systems

- ✓ Protect a given message or item from passive or active attack by a given user
- ✓ Also protect data or resources on the basis of levels of security
- ✓ This is commonly found in the military, where information is categorized as **unclassified (U), confidential (C), secret (S), top secret (TS), or beyond**
- ✓ This concept is equally applicable in other areas
- ✓ For example corporate planning documents and data, accessible by only corporate officers and their staff; next might come sensitive financial and personnel data, accessible only by administration personnel, corporate officers
- ✓ When multiple categories or levels of data are defined, the requirement is referred to as **multilevel security**

A multilevel secure system must enforce the following:

*-**No read up**: A subject can only read an object of less or equal security level. This is referred to in the literature as the **Simple Security Property***

*-**No write down**: A subject can only write into an object of greater or equal security level. This is referred to in the literature as the ***-Property***

Multilevel Security Approach - Reference Monitor

- ✓ *For a data processing system, the approach is based on the reference monitor concept*
- ✓ *Its a controlling element in the hardware and operating system of a computer - regulates the access of subjects to objects on the basis of security parameters of the subject and object*
- ✓ *It has access to a file, known as the security kernel database, that lists the access privileges (security clearance) of each subject and the protection attributes (classification level) of each object*

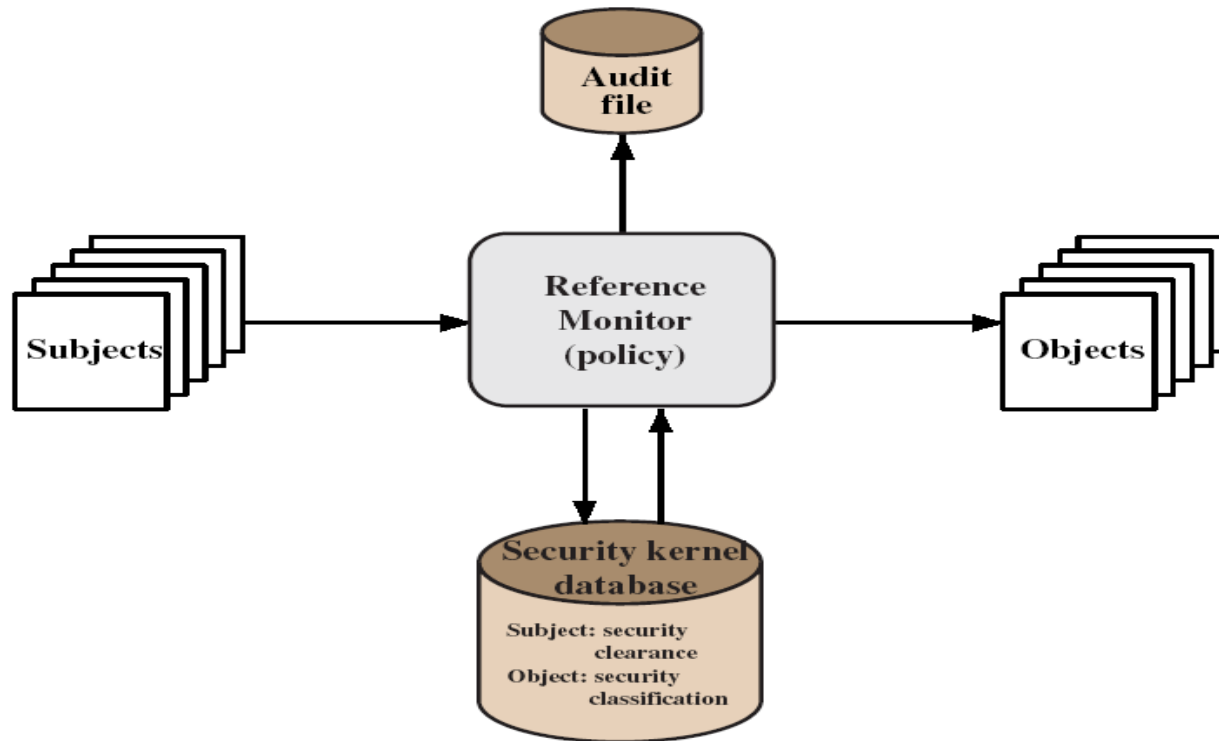


Figure 10.4 Reference Monitor Concept

Reference Monitor Properties

The reference monitor enforces the security rules (no read up, no write down) and has the following properties:

Complete mediation: The security rules are enforced on every access, not just, for example, when a file is opened

-Isolation: The reference monitor and database are protected from unauthorized modification

-Verifiability: The reference monitor's correctness must be provable.

✓ A system that can provide such verification is referred as a trusted system

✓ A final element in Fig 10.4 is an audit file. Important security events, such as detected security violations and authorized changes to the security kernel database, are stored in the audit file

Trojan Horse Defense

✓ One way to secure against Trojan horse attacks is use of a secure, trusted operating system

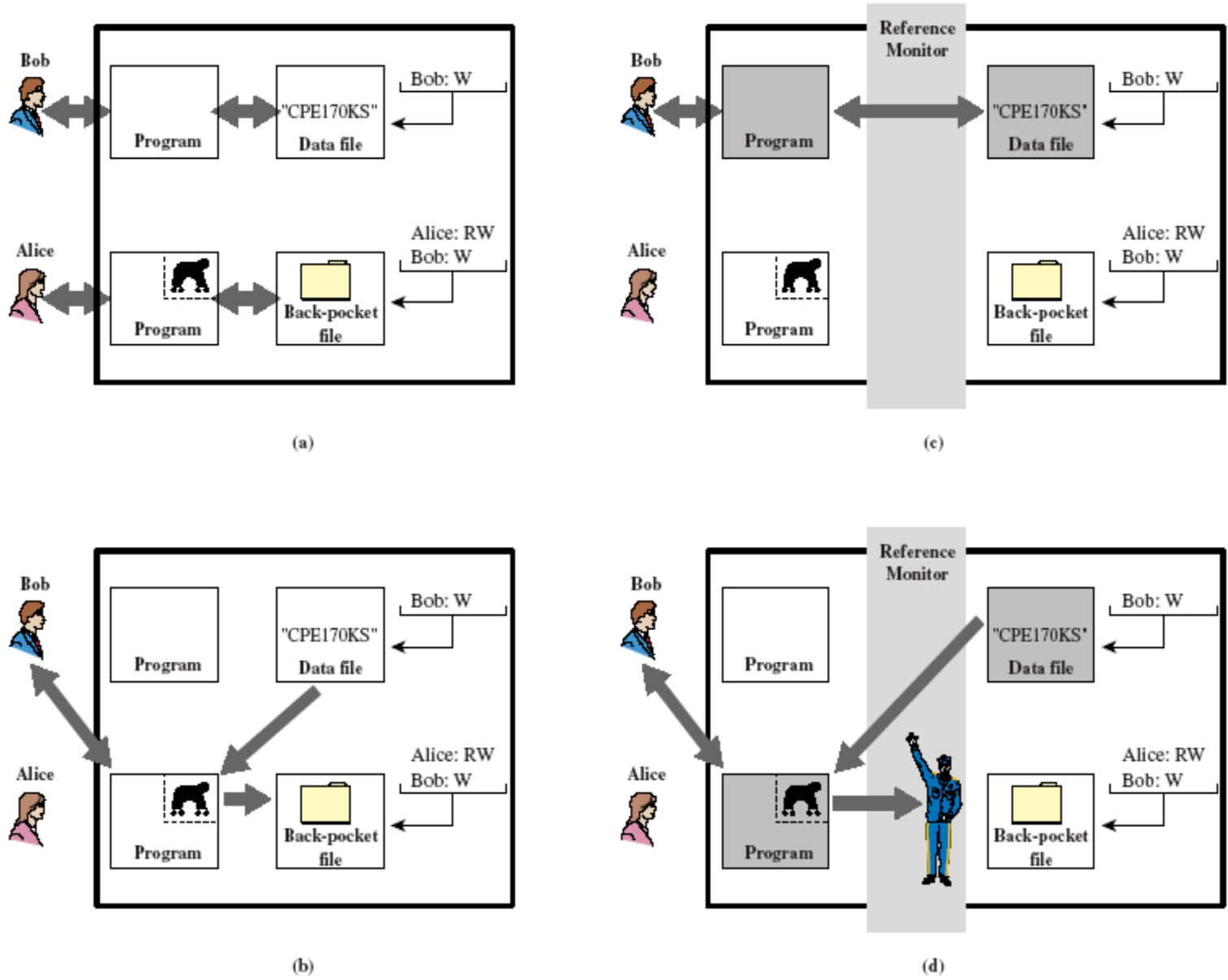


Figure 10.5 Trojan Horse and Secure Operating System

✓ *Fig 10.5 illustrates an example*

✓ *In this example, a user named Bob interacts through a program with a data file containing the critically sensitive character string “CPE170KS”*

✓ *User Bob has created the file with read/write permission provided only to programs executing on his own behalf: that is, only processes that are owned by Bob may access the file*

✓ *The Trojan horse attack begins when a hostile user, named Alice, gains legitimate access to the system and installs both a Trojan horse program and a private file to be used in the attack as a “back pocket”*

✓ *Alice gives read/write permission to herself for this file and gives Bob write-only permission (Fig 10.5a)*

✓ *Alice now induces Bob to invoke the Trojan horse program, by advertising it as a useful utility*

- ✓ *When the program detects that it is being executed by Bob, it reads the sensitive character string from Bob's file and copies it into Alice's back-pocket file (Fig 10.5b)*
- ✓ *Now consider the use of a secure operating system in this scenario (Fig 10.5c)*
- ✓ *Security levels are assigned to subjects at logon time*
- ✓ *In this example, there are two security levels, sensitive and public, ordered so that sensitive is higher than public*
- ✓ *Processes owned by Bob and Bob's data file are assigned the security level sensitive*
- ✓ *Alice's file and processes are restricted to public*
- ✓ *If Bob invokes the Trojan horse program (Fig 10.5d), that program acquires Bob's security level. When the program attempts to store the string in a public file (the back-pocket file), however, the *-property is violated and the attempt is disallowed by the reference monitor*

Intrusion Detection Systems

✓ If an intrusion is detected quickly enough, the intruder can be identified and ejected from the system before any damage is done or any data are compromised

✓ An effective intrusion detection system can serve as a deterrent, so acting to prevent intrusions

✓ Intrusion detection enables the collection of information about intrusion techniques that can be used to strengthen the intrusion prevention facility

✓ Intrusion detection approaches are:

1. Statistical anomaly detection

- Threshold detection*
- Profile based*

2. Rule-based detection

- Anomaly detection*
- Penetration identification*

Statistical anomaly detection

✓ *Involves the collection of data relating to the behavior of legitimate users over a period of time. Then statistical tests are applied to observed behavior to determine with a high level of confidence whether that behavior is not legitimate user behavior*

✓ *It has two categories:*

-**Threshold detection:** *This approach involves defining thresholds, independent of user, for the frequency of occurrence of various events*

-**Profile based:** *A profile of the activity of each user is developed and used to detect changes in the behavior of individual accounts*

Rule-based detection

✓ *Involves an attempt to define a set of rules that can be used to decide that a given behavior is that of an intruder*

✓ *It has two categories:*

-**Anomaly detection:** *Rules are developed to detect deviation from previous usage patterns*

-**Penetration identification:** *An expert system approach that searches for suspicious behavior*

Audit Records: *A fundamental tool for intrusion detection is the audit record. Some record of ongoing activity must be maintained by users as input to an intrusion detection system.*

Basically two plans are used:

- 1. Native audit records*
- 2. Detection-specific audit records*

-Native audit records: *Virtually all multiuser operating systems include accounting software that collects information on user activity.*

-Detection-specific audit records: *A collection facility can be implemented that generates audit records containing only that information required by the intrusion detection system*